



Executive Summary

OVERALL HEALTH

Yellow

Functional but high operational complexity & concentration risk

Action Required

Strong Points

- High automation velocity (180+ npm scripts)
- Strong gate culture + recent hardening
- Modern identity + RBAC evolution
- Good engineering patterns in places

Critical Issues

- Monolithic backend (1,196 lines in one Cloud Run service)
- Webhook HMAC silently skipped when secrets absent
- In-memory OAuth state (breaks on scale)
- Extreme docs sprawl (1,023 .md files)

Top Priority (Score 36)

Close webhook + OAuth state gaps

Est. effort: 1–2 weeks • Highest risk × impact items

Key Risks (if unaddressed)

Forged webhooks (ML/WA) possible when secrets are not set — common pattern in staging/prod.

OAuth/login instability on multi-instance Cloud Run due to in-memory state.

High blast radius: any bug or bad deploy affects calculator + all channels + AI agent.

Slow onboarding + contradictory knowledge from 1,023+ fragmented docs (no clear index).

Technical Debt Register (Top Items)

Priority = (Impact + Risk) × (6 - Effort)

TITLE	SCORE	IMPACT	RISK	EFFORT	OWNER	BUSINESS JUSTIFICATION
In-memory OAuth state	36	4	5	2	Backend	Security + reliability: state loss on restarts / multi-replica deploys breaks logins for operators.
Webhook HMAC skipped when secret absent	36	4	5	2	Security	Direct attack surface for forged ML questions and WA messages (confirmed gap in session transcript).
Monolithic server/index.js (1196 lines)	30	5	5	4	Backend lead	High blast radius on every deploy. Slows refactoring, testing, and independent scaling of AI vs public calc.

TITLE	SCORE	IMPACT	RISK	EFFORT	OWNER	BUSINESS JUSTIFICATION
Brittle test execution (giant && chain)	24	3	4	2	CI/Test	Flaky gates, hidden regressions in pricing/auth/calc. Slow feedback loop.
Documentation fragmentation & sprawl	21	3	4	3	Docs owner	1,023 .md files (29 MB). No clear index. High onboarding tax and contradictory knowledge.
Inconsistent / relaxed dev auth	21	3	4	2	Security	PANELIN_RELAX_DEV_AUTH skips checks on powerful internal/agent surfaces. Easy to leave on in prod.

Full register + justification in TECH-DEBT-REGISTER.md. All items traceable to live code scans.

Security Assessment

OWASP Top 10 (2021) — Key Findings

Category	Status	Details
A02 Cryptographic Failures	At risk	HMAC verification skipped when secret absent (whatsappSignature.js:9, mlSignature.js:19)
A07 Identification & Auth Failures	At risk	In-memory oauthStates; WA verify token can be empty
A04 Insecure Design	At risk	Monolith concentration + in-memory state + webhook event buffers
A01 Broken Access Control	At risk	Broad internal routes + relax-dev flag
A06 Vulnerable Components	Moderate	3 moderate (react-router open redirect, hono transitive)

Critical Gaps: Webhook HMAC best-effort only. OAuth state not durable across replicas. No startup fail-fast for missing critical secrets.

Recommendations (tied to debt): Make secrets mandatory in prod (P0). Persist oauth state to Postgres (P0). Enforce relax-dev-auth strictly (P1).

Key Code Review Findings (File | Line)

Security

- server/index.js:134 — in-memory oauthStates Map
- server/lib/whatsappSignature.js:9 & mlSignature.js:19 — silent skip when secret missing
- server/config.js:53 — overly permissive PANELIN_RELAX_DEV_AUTH

Performance & Maintainability

- server/index.js:1196 — god entrypoint + 30+ side-effect initializers
- src/components/PanelinCalculadoraV3_backup.jsx:7235 lines + RoofPreview.jsx:4238 lines
- package.json "test" script — one giant && chain (no summary, no coverage)

Full list with suggested fixes in CODE-REVIEW-AUDIT.md. 15+ traceable issues catalogued.

Improvement Roadmap

PHASE 0 — CRITICAL (Do Immediately)

1. Make webhook secrets mandatory in production + remove silent skip (3–5 days, Backend+Security)
2. Persist OAuth state (replace in-memory Map) — use Supabase pattern (1 week, Backend)
3. Fix test runner + add coverage baseline (3–5 days, CI owner)

PHASE 1 — Next 3 Months

Decompose server/index.js monolith (extract webhook processors + major workers) • Archive "docs 2/" + create canonical docs INDEX • Enforce relax-dev-auth strictly • Upgrade react-router (fix open redirect) • Add explicit HMAC tests for ML & WA • Promote key browser flows to scheduled smoke • Finish GCP Secret Manager / IAM Phase 1 • Standardize logging to pino everywhere in server/

Phase 2 (6 months): Extract stable "core calc + quotes + identity" boundary • Strengthen dual-write vs Sheets • Add per-route rate limiting • SBOM + scheduled dep scanning.

Phase 3 (12 months): Evaluate splitting Cloud Run service • Reduce script sprawl • Agent coordination hygiene • Complexity & debt review as part of monthly compass.

RECOMMENDATION

The system delivers real value and the team moves fast. The work now is making that velocity sustainable and reducing self-inflicted production risk. Prioritize the three Phase 0 items immediately (est. 3–6 weeks). Re-audit in 90 days.

Generated from full audit (10 deliverables) • June 2026 • All findings traceable to live scans, PROJECT-STATE.md, and code